

Key Security Control Guidance

-  Home
-  Documentation
-  API Reference
-  Code Samples
-  Announcements
- Models
- Release Notes
- FAQ
- GitHub
- Videos

GET STARTED

- Welcome to SP-API Documentation
- What is the Selling Partner API?
- Selling Partner API Onboarding Overview

Key Security Control Guidance

Learn how to implement key security controls to achieve Amazon Data Protection Policy compliance and maintain SP-API access.

Implementing robust security controls is fundamental to protecting Amazon Selling Partner API applications and the sensitive seller data they process. This guide outlines essential security controls that align with Amazon's [Data Protection Policy](#) (DPP) and [Acceptable Use Policy](#) (AUP). Solution providers must implement these key security controls to build secure and compliant applications that protect customer data and maintain Amazon marketplace access.

Amazon Data Protection Policy (DPP) requirements

The Amazon Data Protection Policy contains two categories related to security requirements:

- Section 1. General Security Requirements,

- Terminology
- Frequently Asked Questions

CHANGELOG

SP-API Release Notes

SP-API Deprecation Schedule

SP-API Product Metadata Updates

DIRECTORIES

SP-API Models

SP-API Seller Use Cases

SP-API Vendor Use Cases

Seller Central URLs

Vendor Central URLs

REGISTRATION

SP-API Registration Overview

Developer Registration Request Status

Third-Party Provider Registration

Service Provider Registration and Role Approval Process Overview

Website Guidelines for Public Developers and Service Providers

User Permissions for Service Providers

Register your Application

Update your Application Information

Rotate your Application's LWA Credentials

View your Application Information and Credentials

Learn How Sellers Authorize Service Providers

Selling Partner API Roles

Policies and Agreements

About Facial Data

Key Security Control Guidance

which includes requirements for all Solution providers building SP-API applications.

- **Section 2. Additional Security Requirements for Personally Identifiable Information (PII)**, which includes additional requirements for Solution providers performing restricted operations on SP-API that involve personally identifiable information (PII).

This guide addresses all applicable DPP requirements.

Critical response requirements and timelines

Solution providers must abide by the following critical response requirements and timelines. Failure to follow these requirements can result in regulatory violations and loss of SP-API access.

Immediate response requirements

To effectively respond to critical security risks, solution providers must:

- Notify Amazon at security@amazon.com within **24 hours** of any security incident.
- Disable and remove access for terminated employees within **24 hours**.
- Resolve critical-risk vulnerabilities within

AUTHORIZATION

Authorize Applications



Renew Authorizations

Revoke Authorizations

Authorization Limits

Special Authorization Types



INTEGRATION

Building Robust Amazon SP-API Applications

SP-API SDKs



Delete an Application From Your Developer Account

CALLING THE SP-API

Configuration Details



Key Security Control Guidance

seven days of discovery.

- Resolve high-risk vulnerabilities within **30 days** of discovery.
- Delete personally identifiable information (PII) within **30 days** after order delivery.

Operational requirements

To maintain SP-API access and DPP compliance, solution providers must perform the following tasks at the required cadences:

Required Task	Cadence
Conduct log reviews	Bi-weekly
Update anti-malware tools	Monthly
Conduct vulnerability scans on all systems	Monthly
Review all personnel and service access	Quarterly
Maintain inventory of all devices and systems that handle PII	Quarterly
Test backup and recovery procedures	Quarterly
Rotate Amazon API	Annually

Call Structure	>
Development Tools	>
Performance Management	>
SOLUTION PROVIDER PORTAL	
Manage Users in Solution Provider Portal	
Manage Your Business And Contact information in Solution Provider Portal	
Update Your Developer Profile in Solution Provider Portal	
Unify Your Developer Accounts	
Verify Your Identity in Solution Provider Portal	
API Usage Metrics in Solution Provider Portal	

TUTORIALS

Tutorial: Subscribe to the ORDER_CHANGE Notification
Tutorial: Test Selling Partner API Endpoints
Tutorial: Automate your SP-API Calls Using a C# SDK
Tutorial: Automate your SP-API Calls Using a Java SDK
Tutorial: Automate your SP-API Calls Using a JavaScript SDK for Node.js
Tutorial: Automate your SP-API Calls Using a Python SDK
Tutorial: Automate your SP-API Calls using a prebuilt C# SDK
Tutorial: Automate your SP-API Calls using prebuilt Java SDK
Tutorial: Automate your SP-API Calls using a prebuilt JavaScript SDK
Tutorial: Automate your SP-API Calls using prebuilt PHP SDK

Required Task	Cadence
keys	
Rotate encryption keys	Annually
Conduct security awareness training for all approved users	Annually
Perform penetration testing	Annually
Conduct formal third-party security assessments	Annually

Data retention limits

To minimize security exposure and ensure compliance, solution providers must adhere to the following data retention limits:

Data Type	Retention Limit
PII data	30 days after order delivery
Non-PII data	18 months maximum
Security logs	12 months minimum

Baseline security controls

Establish the foundational protection measures that are

Tutorial: Automate your SP-API calls using a prebuilt Python SDK

Tutorial: Authorize Multiple Vendor Central Accounts with a Single SP-API Application

Tutorial: Retrieve Merchant Shipping Templates

Tutorial: Grant the SP-API Permission to an Amazon SQS Queue

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier

TROUBLESHOOTING

Troubleshoot SP-API Errors

URL Encoding

Resolve Common HTTP and Authorization Error Codes

External Fulfillment Errors 

Listings Items API Issues Troubleshooting 

SELLING PARTNER APPSTORE

What is the Selling Partner Appstore?

List Your App on the Selling Partner Appstore

Edit Your Appstore Listing

Check Listing Status

Appstore Ratings and Reviews

Press Releases and Promotions

SERVICE PROVIDER NETWORK

List Your Service

SECURITY AND COMPLIANCE

SP-API Security and Compliance Overview

Amazon Selling Partner API Guard Implementation Guide 

required for all SP-API applications.

Password and authentication

This control relates to section **1.4 Credential Management** of the DPP.

Compromised credentials provide direct access to databases, servers, and customer data. Attackers use [Brute Force Password attacks](#) and other methods to steal credentials for financial gain.

Solution providers must:

- Establish password complexity requirements: minimum 12 characters with mixed case letters, numbers, and special characters, and must not include any part of the user's name.
- Configure password history to prevent reuse of the last 10 passwords and configure password lifecycle settings with a minimum password age of 1 day and a maximum password expiration period of 365 days.
- Deploy [Multifactor Authentication \(MFA\)](#) for all accounts that use approved second factors (TOTP, hardware tokens, or biometric authentication).
- Implement encryption at rest for all SP-API credentials using industry-standard encryption (minimum AES-128, recommended

AES-256) and store within a secure key management systems to prevent unauthorized access.

VAT Calculation Service

>

- Rotate API keys annually with automated processes and maintain key inventories.
- Use directory services such as [AWS Directory Service](#) or Microsoft Active Directory for centralized enforcement.

Amazon Seller Data Access

Best Practices

>

Key Security Control Guidance

Logging and Monitoring for Amazon SP-API Applications

Network Protection Guidance

Protect Amazon API Applications with Data Encryption

Protect Amazon API Applications with Data Retention and Recovery

Protect Amazon SP-API Applications with Incident Response

Safeguarding Sensitive Credentials

Vulnerability Management

- Implement account lockout controls by monitoring anomalous usage patterns and failed authentication attempts. User accounts must be locked after 10 or fewer unsuccessful login attempts.
- Encrypt all information in transit using secure protocols such as TLS 1.2 or higher, SFTP, and SSH-2, and enforce this control across all applicable internal and external endpoints. Where transport-level encryption terminates in untrusted multi-tenant infrastructure (for example, untrusted proxies), message-level encryption must be used.

A+ CONTENT API

A+ Content API

>

A+ Content Examples

AMAZON WAREHOUSING AND DISTRIBUTION API

Amazon Warehousing and Distribution API

>

- Permanently and securely delete Information in accordance with Amazon's deletion notices within 30 days of Amazon's request, unless retention is required to meet legal, tax, or regulatory obligations.

Amazon Warehousing and Distribution API v2024-05-09 Reference

APP INTEGRATIONS API

App Integrations API

>

Non-PII data must be deleted within 18 months unless longer retention is required by applicable laws or regulations.

APPLICATION MANAGEMENT API

Application Management API

>

CATALOG ITEMS API

Catalog Items API

>

Catalog Items API Rate Limits

Catalog Items API v2022-04-01 Reference

CUSTOMER FEEDBACK API

Customer Feedback API

>

Customer Feedback API Rate Limits

DATA KIOSK

Data Kiosk API

>

Data Kiosk Schema Explorer User Guide

Data Kiosk Query Processing Finished Notification

Building Data Kiosk workflows guide

Vendor Analytics Dataset Use Case Guide

Schedule Data Kiosk Queries

DELIVERY BY AMAZON API

Delivery by Amazon API

>

Asset management

This control relates to section **2.3 Asset Management** of the DPP.

Solution providers must not store PII on removable media, personal devices, or unsecured public cloud apps (for example, publicly shared Google Drive links) unless encrypted with AES-128 (or higher) or RSA-2048 encryption. Lost devices and unauthorized cloud storage frequently result in data breaches.

Solution providers must:

- Maintain quarterly inventories of all devices, systems, and applications that handle PII.
- Establish baseline security configurations with regular patches and updates across all managed assets.
- Restrict PII storage to approved systems only. Prohibit removable media, personal devices, or unsecured cloud applications.
- Implement data loss prevention (DLP) tools to monitor and prevent unauthorized data movement.

EASY SHIP API

Easy Ship API

>

- Ensure secure disposal of printed materials that contain PII through approved destruction methods.
- Implement formal change control processes.
- Maintain segregation of duties between change approvers and testers for all systems that handle PII.

EXTERNAL FULFILLMENT

External Fulfillment Inventory API

>

Access review

This control relates to section **1.2 Access Management** of the DPP.

External Fulfillment Returns API

>

Excessive user access and dormant accounts create security vulnerabilities.

External Fulfillment Shipping API

>

Attackers exploit over-privileged accounts and shared credentials to gain unauthorized access to sensitive data.

External Fulfillment Errors

External Fulfillment APIs Rate Limits

Solution providers must:

- Establish formal user access registration processes with unique identifiers for each person and eliminate generic, shared, or default login credentials.
- Apply [least privilege](#) and grant minimum necessary access to all user and service accounts.
- Implement baselining mechanisms to ensure only required user accounts maintain access to information.

FULFILLMENT BY AMAZON (FBA)

FBA Inventory API

>

FBA Inventory Dynamic Sandbox Guide

FEEDS API

Feeds API

>

Feed Type Values

>

Feeds JSON Schemas

Feeds API Best Practices

Feeds API FAQ

Feeds API Rate Limits



FINANCES

Finances API



Key Security Control Guidance

- Prohibit employees and contractors from storing information on personal devices.
- Conduct quarterly reviews of all personnel and services with access to information.
- Disable and remove access within 24 hours for terminated employees.

Data protection controls

Protect customer data from unauthorized access and ensure compliant data handling.

Transfers API



FULFILLMENT INBOUND API

Fulfillment Inbound API



Data encryption at rest

This control relates to section **2.4 Encryption at Rest** of the DPP.

Unencrypted data at rest exposes customer PII to unauthorized access through compromised systems, physical device theft, or insider threats. Without proper encryption and key management, organizations cannot adequately protect customer data.

Solution providers must:

- Create data classification documents that identify all data that require encryption.
- Use AES-128 or RSA-2048 bit keys (or higher) to encrypt all PII data.
- Apply encryption to end-device drives, servers,

Fulfillment Inbound API FAQ

Migrating Fulfillment Inbound workflows

Fulfillment Inbound API Rate Limits

FULFILLMENT OUTBOUND API

Fulfillment Outbound Dynamic Sandbox Guide

Fulfillment Outbound API



Key Security Control Guidance
databases, and backup
storage systems.

- Encrypt SP-API keys and credentials and never expose them in plain text.
- Deploy Key Management Systems (KMS) that cover the complete key lifecycle.
- Use cryptographically secure methods to generate keys and store the keys in dedicated KMS with access controls.
- Rotate encryption keys at least annually and revoke compromised keys immediately.

For additional guidance on how to identify systems that require encryption, refer to the [Data classification whitepaper](#).

Anti-malware controls

This control relates to section **1.1 Network Protection** of the DPP.

Malware attacks through phishing emails, compromised websites, and malicious downloads can steal credentials and exfiltrate customer PII. Robust anti-malware defenses prevent data breaches and business disruption.

Solution providers must:

- Apply [network segmentation](#) and implement network firewalls, access control

Fulfillment Outbound API Rate Limits

MCF Best Practices

INVOICING

Invoices API >

Invoices API FAQ

LISTINGS

Listings Items API >

Listings Items API Rate Limits

Listings Restrictions API >

Listings Restrictions API Rate Limits

Manage Product Listings with the Selling Partner API

Building Listings Management Workflows Guide

Understanding Amazon listing status and seller-fulfilled inventory management

Listings Management Workflow Migration >

Manage Amazon Haul, Advanced Multiple-Offer, and Multiple-Fulfillment Use Cases

Listings APIs FAQ

Product Type Definitions API >

Product Type Definitions API Rate Limits

MERCHANT FULFILLMENT API

Merchant Fulfillment API >

Key Security Control Guidance

lists, and intrusion detection/prevention systems (IDS/IPS).

- Deploy and maintain up-to-date antivirus software on all servers and endpoints that access SP-API data.
- Implement endpoint protection solutions that prevent users from disabling anti-virus software.
- Update anti-virus and anti-malware tools at least monthly.
- Restrict system access to approved internal employees who have completed annual data protection and IT security awareness training ("Approved Users").
- Maintain secure coding practices and implement Group Policy (Windows) or Mobile Device Management (MDM) solutions to enforce security policies.
- Deploy security information and event management (SIEM) systems to correlate security events and detect advanced threats.
- Adopt Software Development Life Cycle (SDLC) frameworks with integrated security testing.

Data retention processes

This control relates to section **2.1 Data Retention** of the

DPP.

MESSAGING API

Messaging API >

NOTIFICATIONS API

Notifications API >

Notification Type Values

Tutorial: Subscribe to the ORDER_CHANGE Notification ↗

ORDERS API

Orders API >

Retaining customer PII beyond defined business or regulatory requirements may increase the organization's exposure and introduce potential compliance considerations. Many solution providers store complete customer records when only specific non-PII elements are needed for business operations.

Solution providers must:

- Implement clear data tagging systems to distinguish PII from non-PII data.
- Document data classification schemas and ensure consistent application across all storage systems.
- Retain PII for no longer than 30 days after order delivery unless required by law for specific compliance purposes.
- Retain non-PII data for up to 18 months maximum unless longer retention is required by applicable laws.
- Use secure deletion methods that follow industry-standard sanitization processes (NIST 800-88).
- Archive PII in encrypted storage only when required by law for longer retention periods.

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier ↗

Orders API Migration Guide

Orders API Rate Limits

PRODUCT FEES API

Product Fees API >

Monitoring and incident

response controls

Identify security threats and contain incidents with speed.

Identification of potential incidents

This control relates to section **2.6 Logging and Monitoring** of the DPP.

Security incidents often go undetected for extended periods, allowing attackers to establish persistence and exfiltrate sensitive data. Robust monitoring identifies threats that target SP-API applications and unauthorized PII access.

Solution providers must:

- Retain security logs for at least 12 months and implement centralized log collection from all systems that handle Amazon data.
- Ensure that logs capture event data that includes success/failure status, timestamps, user identities, access attempts, data changes, and system errors.
- Maintain log integrity through access controls and exclude PII unless required by legal or regulatory requirements.
- Deploy Security Information and Event Management (SIEM) systems or [Intrusion Detection & Prevention Systems](#) for threat detection.

PRODUCT PRICING API

Product Pricing API

>

Product Pricing API and Notifications FAQ

Price Adjustment Automation Workflows Guide

Manage automated pricing rules with SP-API

REPLENISHMENT API

Replenishment API

>

REPORTS API

Reports API

>

Report Type Values

>

Reports JSON Schemas



Reports API FAQ

SALES API

Sales API



SELLER WALLET API

Seller Wallet API



Seller Wallet API Rate Limits

SELLERS API

Sellers API



SERVICES API

Services API



- Review logs in real-time using automated analysis tools or conduct bi-weekly manual reviews to catch suspicious activities.
- Monitor all access channels, including service APIs, storage-layer APIs, administrative dashboards, and user interfaces.
- Deploy dark web monitoring services and data exfiltration detection systems to monitor for unauthorized data movement beyond protected boundaries.
- Monitor for multiple unauthorized API calls, unexpected request rates, and anomalies in access patterns.
- Document all monitoring alarm investigations in formal Incident Response Plans.

Incident management procedures

This control relates to section **1.6 Risk Management and Incident Response Plan** of the DPP.

Poor incident management leads to extended data exposure, regulatory penalties, and reputation damage. Structured incident response procedures enable rapid containment and recovery.

Solution providers must:

SHIPMENT INVOICING API

Shipment Invoicing API



SHIPPING API

Shipping API v2 Resources



Shipping API v1 Reference

SOLICITATIONS API

Solicitations API

>

SUPPLY SOURCES API

Supply Sources API

>

Multi-Location Inventory Integration Guide

Supply Sources API Rate Limits

TOKENS API

Tokens API

>

UPLOADS API

Uploads API

>

VEHICLES API

Vehicles API

>

Vehicles API Rate Limits

VENDOR DIRECT FULFILLMENT APIS

Vendor Direct Fulfillment Dynamic Sandbox Guide

Vendor Direct Fulfillment Workflow Guide

SP-API Bill-to-Party Addresses

- Maintain thorough incident response plans approved by senior management and reviewed every six months and updated after major infrastructure changes or lessons learned.
- Include all standard incident response phases (preparation, identification, containment, eradication, recovery, lessons learned) with specific procedures for different incident types.
- Establish annual risk assessment and management processes reviewed by senior management and document roles, responsibilities, and decision-making authority for all team members.
- Designate an Incident Management Point of Contact (IMPOC) and maintain current IMPOC contact details.
- Maintain updated contact lists with clear internal escalation paths and notify Amazon at security@amazon.com within 24 hours of detecting security incidents.
- Establish procedures for notifying government agencies as required by law and create customer communication protocols for incident status updates.

VENDOR DIRECT FULFILLMENT TRANSACTION STATUS API

Vendor Direct Fulfillment Transaction Status API >

VENDOR DIRECT FULFILLMENT INVENTORY API

Vendor Direct Fulfillment Inventory API >

VENDOR DIRECT FULFILLMENT ORDERS API

Vendor Direct Fulfillment Orders API >

VENDOR DIRECT FULFILLMENT SHIPPING API

Vendor Direct Fulfillment Shipping API >

VENDOR DIRECT FULFILLMENT PAYMENTS API

Vendor Direct Fulfillment Payments API >

VENDOR RETAIL PROCUREMENT INVOICES API

Vendor Retail Procurement Invoices API >

VENDOR RETAIL PROCUREMENT ORDERS API

Vendor Retail Procurement Orders API >

Vulnerability management

This control relates to section **2.7 Vulnerability Management** of the DPP.

Unpatched vulnerabilities create entry points that attackers exploit to compromise SP-API applications and access customer data. Systematic vulnerability identification and timely remediation prevent security breaches.

Solution providers must:

- Conduct vulnerability scanning at least every 30 days across all systems that process or store Amazon data.
- Perform annual penetration testing using qualified security professionals or third-party firms and scan application code prior to each software release.
- Test both external-facing infrastructure and internal systems with professional tools and methodologies.
- Remediate critical risk vulnerabilities within 7 days and high-risk vulnerabilities within 30 days of discovery.
- Review [AWS Penetration Testing](#) guidance before testing AWS services.
- Maintain geographically separated secondary/backup sites with defined Recovery Time Objectives (RTO)

VENDOR RETAIL PROCUREMENT SHIPMENTS API

Vendor Retail Procurement Shipments API >

Third-party risk management controls

Prevent risks associated with third-party subcontractors and vendors.

This control relates to section **2.8 Subcontractors** of the DPP.

VENDOR RETAIL PROCUREMENT TRANSACTION STATUS API

Vendor Retail Procurement Transaction Status API >

Third-party vendors with inadequate security practices can compromise SP-API applications and customer data. Proper risk assessment ensures these parties maintain security standards.

Powered
by

Solution providers must:

- Conduct annual risk assessments of all vendors and subcontractors before granting access to Amazon data.

Key takeaways and next steps

- Implement the ten essential security controls outlined in this guide to achieve compliance with Amazon's [Data Protection Policy](#) and maintain SP-API access.
- Prioritize critical response requirements including 24-hour incident notification, 7-day critical vulnerability remediation, and 30-day

PII deletion to avoid compliance violations.

- Establish robust third-party risk management programs.
- Review your current security posture against these controls and develop a formal implementation plan with assigned responsibilities and timelines.
- Regularly review and update your security controls to address evolving threats and policy requirements.
- Consult the latest version of the [Data Protection Policy](#) and [Acceptable Use Policy](#) for the most up-to-date compliance requirements.

Notices

Amazon sellers and Solution providers are responsible for making their own independent assessment of the information in this document. This document: (a) is for informational purposes only, (b) represents current practices, which are subject to change without notice, and (c) does not create any commitments or assurances from Amazon.com Services LLC (Amazon) and its affiliates, suppliers, or licensors. Amazon Selling Partner API (Amazon SP-API) products or services are provided "as is" without warranties, representations,

or conditions of any kind, whether express or implied. The responsibilities and liabilities of Amazon regarding SP-API and Seller Central are controlled by Amazon's agreements (including the Amazon Selling Partner API Developer Agreement or the Amazon Selling Partner API License Agreement), and this document is not part of, nor does it modify, any agreement between Amazon and any party.

 Updated 18 days ago

←

Best Practices

Logging and Monitoring for Amazon SP-API Applications →

Did this page help you?

 Yes

 No